

Bölüm A: Teori ve İstihbarat (Research & Logic)

Bu bölümde henüz Wireshark açmanıza gerek yoktur. Amacımız, analiz yapmadan önce "Trafik Felsefesini" kavramaktır. Aşağıdaki soruları kopyala-yapıştır yapmadan, bir mühendis edasıyla (kendi cümlelerinizle) yanıtlayın.

1. Mekanik ve Altyapı:

Promiscuous Mode (Gelişigüzel Mod): Wireshark direkt olarak paket trafiğini inceleme aracıdır. Paket dağıtımları unicast, broadcast ve multicast olmak üzere 3 şekilde oluşur. Bu mod kapalıysa direkt olarak tarafına iletilen yayınları yakalar. Yani, kendisi ile gerçekleşen birebir unicast, broadcast ve üyesi olduğu multicastleri yakalar. Ağa bağlı olan diğer cihazların birebir unicastlerini yakalayamaz.

Hub vs. Switch Farkı: Hub cihazları broadcast yapıp doğru kullanıcıya paketleri iletirken, switch cihazlar ise direkt olarak paket sahibinin mac adresinin hangi porta bağlı olduğunu bilir. Bu sayede direkt olarak trafiği izole eder. Saldırgan, bunu aşmak için de ARP Poisoning'e başvurur, ki bu da Man in the Middle saldırısına ortaya çıkartır. Ali'ye ben Veli'yim, Veli'ye ben Ali'yim diyip, sahte ARP paketleri gönderir. Sonrasında ise Ali'den Veli'ye giden her paket önce saldırgana, sonra asıl hedefine iletilir. Saldırgan ise paketleri görebilir ve değiştirebilir.

Pcap vs. Log: En bilinen tabirle Log "olay raporu" iken, Pcap "olayın fotoğrafı" olarak görülür. Log dosyaları küçüktür, dolayısıyla içerisindeki bilgiler de azdır. Kurallar bütününcü gerçekleşmiş kayıtlardır. Aradıkları ve tuttukları şeyler bellidir: zaman, kaynak/hedef, port, eylem, özet. Pcap ise büyüktür, dolayısıyla barındırdığı içerik de fazladır, ham veridir. Log dosyası "bir dosya gönderildi" derken, Pcap, "gönderilen dosya bu" der. Pcap içerisindeki veriler, el sıkışmasından başlayıp, verinin şifrelenmesine kadar gider. İncelenmesi zordur, ancak asıl konu orada gerçekleşir. Bu sebeple, önce olay raporuna (log) bakılır, zaman ve hedef daraltılır; aranan şeyin nerede arandığı öğrenildikten sonra Pcap dosyasını incelemeye başlanır.

2. Protokol Anatomisi:

3-Way Handshake (Üçlü El Sıkışma): Üçlü El Sıkışma TCP; paketlerin doğru ve güvenli bir şekilde gittiğini onaylamak için gerçekleşen basit bir güvenlik şeklidir.

İstemci, numarayı çevirir ve arar. “Bak ben burdayım” demektir. SYN flagını set etmiş bir şekilde sunucuya bir paket gönderir. Tabii, içerisinde de bir sıra numarası barındırır. Sunucu ise paketi alır (SYN-ACK), “Selam, ben de burdayım; bağlantı tamam, konuşalım.” der ve onaylar. Onaylama işleminden sonra da SYN-ACK flaglı paketi istemciye geri gönderir: +1 sıra numarası ile. İstemci de gelen SYN-ACK flaglı paketi onaylar ve kendisini de ACK paketini tekrar sunucuya onaylatır (+1 sıra numarası) ve bu sayede iletişim bağlantısını kurmuş olur.

TCP vs. UDP: TCP kontrolcü, UDP ise kontrolsüz ilerleyen protokollerdir. TCP kesin olarak paketin doğru kişiye ulaştığından emin olmak ister, sırayı kontrol eder ve tekrar sıraya dizer. UDP ise ne kadar karışık olursa olsun teslim eder, üst katmana bırakır. UDP hız, TCP güvenilirliktir. Banka uygulamalarının en minimalist bir paket kaybı bile büyük kayıplara yol açabileceği için TCP tercih edilir. Paket ulaşmazsa TCP tekrar iletir (retransmission). Streaming uygulamalarının ise en ufak bir paket kaybı, en fazla çözünürlük kaybı yaratacağı için UDP tercih edilir. Güvenlik problemi yoktur, en fazla kısa süreli donma yaşanır, paket devam edince donma sorunu gider. Paket doğru iletilmezse de “benim işim bitti” der, yoluna devam eder.

Sequence Number (Sıra Numarası): Paketlerin ne olduğunu net bir şekilde anlamamız gerekiyor. Paketler, verilerin parçalanmış halidir. Her parçaya da uygun bir sıra numarası verilir. Veri akışı sırasından ziyade, byte sırasındır. Bu sayede paketler (byteler) birleştirildiği zaman, eksik paket var mı yok mu anlaşılır; retransmissiona gidilir. Paketlerin sırası karışırsa, buffer (geçici bellek - tampon) devreye girer. 3. paket gelmedi ise, ancak 4. ve 5. paket geldiyse, TCP direkt olarak 4. ve 5. paketi sıraya alır. Göndericiye ACK=3 paketlerini defalarca iletir, gönderici ise 3. paketin kayıp olduğunu anlayıp tekrar 3. paketi iletir. TCP sıraya aldığı 4. ve 5. paketle birlikte, 3. paketi birlikte iletir, 3. paketin byteleri ve sırada bekleyen 4. ve 5. paket bytelerini birleştirir.

3. Kimlik ve Adresleme:

ARP Protokolü (Who has?): Bir bilgisayar 192.168.1.1 adresine ping atmak istediği zaman, bir paket gönderir. Bu gönderilen paket ağda iletmek için MAC adresine ihtiyaç duyar, MAC adresi bilinmiyorsa fiziksel adres eksikliğini kapatmak ister. Bu sebeple anlık olarak bir broadcast başlatılır. Ağa bağlı her cihaz, bu paketi alır, yalnızca

192.168.1.1 adresi bu pakete cevap verir ve geri dönüş olarak MAC adresini unicast olarak geri iletir. Diğer tüm cihazlar paketi çöpe atar.

DHCP (DORA Süreci):

Discover (Keşif): Bir cihaz ağa bağlanır, mevcutta IP adresi olmadığı için 0.0.0.0 IP adresine sahiptir. Bu sebeple ağdaki tüm DHCP sunucularına broadcast yayını yapar, IP talep eder. Hedef IP: 255.255.255.255; Hedef Mac: FF:FF:FF:FF.

Offer (Teklif): DHCP sunucusu, broadcast yayınına cevap vermek için tüm ağı tarayıp havuzda bulunmayan IP'leri tespit eder. Boştaki IP adresini 0.0.0.0 cihazına unicast olarak teklif eder.

Request (Talep): Cihaz unicaste cevap verir ve teklifi onaylar. Tekrar bir broadcast gerçekleştirir ve onayını DHCP sunucularına bildirir. Eğer birden fazla DHCP sunucusu var ise, ilk gelen teklifi kabul eder. Kalan DHCP sunucularına ise, aldığı IP'i bildirir.

Acknowledge (Onay): DHCP sunucusu son onayı verir. Gateway, Subnet Mask ve IP 0.0.0.0 cihazına atanır. Unicast olarak atanan IP'e son onayı bildirir.

DNS (İnternetin Rehberi): Domain name system olarak da bilinen, IP'lerin yazıya dökülmüş halidir. Her IP'nin net bir name server karşılığı vardır. Ancak bunların tanımlanmış olması gerekiyor. "www.google.com" adresine girilmek istendiğinde, ilk olarak istemci makine adresi çözmeye çalışır.

Makine içerisindeki cacheler (önbellekler) kontrol edilir, daha önce girildi mi, girilmedi mi, biliniyor mu ona bakılır. Bilinmiyorsa ISS devreye girer. İstemci makine ISS'yi devreye sokar, IP'yi öğrenmeye çalışır. ISS'de bilmiyor ise kök sunucuya iletir. Kök sunucu da IP'yi arar, bulamazsa Top Level Domain'e gider. TLD ise IP "bende de yok, ama şuraya bak" der. Authoritative servers'e iletilir ve IP buradan zincirleme olarak geri döner.

4. Şifreleme ve Kör Noktalar:

HTTPS ve Şifreleme: Uygulama katmanındaki veriler HTTPS ile uçtan uca şifrelenir. Tüm veri anlamsız byteler arasında kaybolur. Ancak, veri şifrelense de; iletilmesi gereken verinin başarılı olması için bazı detaylar açıkta bırakılır.

Bunlar: Kaynak IP, Hedef IP, Portlar, TLS, Sertifika Bilgileri, Zaman Damgası, Boyut ve SNI olmak üzere devam eder. Kısacası, metadatalar elimizde kalır.

Ana veriyi görmek için istemci tarafının private keyi veya TLS session anahtarı gerekir. Bunlarla birlikte wiresharktaki trafik ve şifreleme çözülür.

Man-in-the-Middle (Ortadaki Adam): Man in the Middle saldırısı, trafik akışını kendi üzerine çekmektir. Saldırgan hem kurbanla TLS oturumu, hem de sunucuyla bir TLS oturumu oluşturmak ister. Bunu yapmak için de saldırgan kendisini Veli'ye Ali olarak, Ali'ye veli olarak tanıtır, sertifikaları kullanır. Hedef site adına tanımlanmış olan sahte sertifikayı kurbanın tarayıcısına iletir. Kurban bu sertifikayı kabul ederse veya kök dizinde zaten varsa; saldırgan başarılı olmuş olur ve şifreli veriler okunabilir hale gelir.

5. Saldırı İmzaları:

Port Taraması (Port Scanning): 3 Way Handshake ile normal bağlantı sağlanırken: SYN, SYN – ACK, ACK, Veri olarak gider. Port taramasında ise SYN, SYN-ACK, RST ile bitirilir. Wireshark üzerinde analiz yapıldığında, anlık olarak gerçekleşen ardışık portlara giden SYN paketleri ele verebilir. Kısacası 3 way handshake tamamlanmaz, yarıda kesilir.

Denial of Service (DoS): Saldırgan, 3 way handshake'i silaha döndürür. Hedefe SYN paketi iletir, hedef SYN – ACK ile tepki verir ve ACK paketini bekler (Yarım Açık Bağlantı). Bu bekleme bir sıra oluşturur. Saniyede gelen 100.000 adet SYN paketine SYN – ACK iletilmesi sonucu, her saniye 100.000 kuyruk ve beklenen ACK paketi demektir. Bu sıra şişer (SYN Backlog Queue) , bu sebeple ACK paketini iletmek isteyen asıl kullanıcılar da paketini iletemez, bağlantıyı tamamlayamaz.

Bölüm B: Saha Eğitimi ve Araç Hakimiyeti (TryHackMe - Wireshark 101)

1. Arayüz ve Renkler (Task 3: Wireshark Overview) Wireshark ekranı 3 ana panele ayrılır: Packet List, Packet Details, Packet Bytes.

Soru:

```
› Frame 47277: 82 bytes on wire (656 bits), 82 bytes captured (656 bits) on interface ens5, id 0
› Ethernet II, Src: 06:0b:3a:46:2c:ed (06:0b:3a:46:2c:ed), Dst: 06:c3:ee:de:96:cd (06:c3:ee:de:96:cd)
› Internet Protocol Version 4, Src: 10.82.109.150, Dst: 10.82.111.101
› Transmission Control Protocol, Src Port: 44368, Dst Port: 80, Seq: 129705, Ack: 69996888, Len: 16
```

Katman 2 (Ethernet II) - Fiziksel Haberleşme

Kaynak MAC: 06:0b:3a:46:2c:ed

Hedef MAC: 06:c3:ee:de:96:cd

Katman 3 (IP) - Adresleme

Kaynak IP: 10.82.109.150

Hedef IP: 10.82.111.101

Katman 4 (TCP) - Taşıma ve Portlar

Kaynak Port: 44368

Hedef Port: 80

Soru: Wireshark'ta bazı paketler Kırmızı veya Siyah arka planla gösterilir (Bad TCP vb.).
Bu renklerin analist için anlamı nedir? (Kısaca açıklayın).

Siyah arka planlar kritik olanlardır. Retransmission (paket ulaşmadı veya onay gelmedi) olabilir, out-of-order (paketler karmaşık sırayla geldi) olabilir vs.

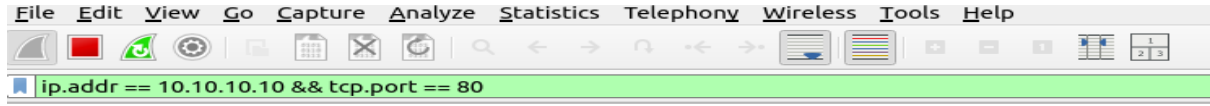
Kırmızı olanlar ise bağlantının aniden koparıldığını veya gelen paketin bozulduğunu belirtir.

Analist için direkt göze çarpan ve kritik anlarda neye bakması gerektiğini belirten renklerdir.

2. Filtreleme Sanatı (Task 5: Filtering Captures) Samanlıkta iğne aramanın tek yolu filtrelerdir.

Görev: Sadece IP adresi 10.10.10.10 olan VE (AND) portu 80 olan paketleri görmek istiyorsunuz. Yazmanız gereken filtre komutu nedir?

Kanıt:



3. OSI ile Paket İlişkisi (Task 6: Packet Dissection)

Soru: Packet Details panelinde Ethernet II başlığını genişletin. Burada gördüğünüz "Source" ve "Destination" adresleri, OSI modelinin hangi katmanına (Layer) aittir? (IP mi, MAC mı?)

Cevap: MAC adresleri her zaman onaltılık (hexadecimal) formatta görünür. Bu sebeple source ve destination MAC'tir. Layer3 IP iken, Layer2 MAC'tir.

4. ARP Trafiği (Task 7: ARP Traffic) Ağdaki "Kimlik Sorma" mekanizması.

Soru: ARP protokolü iki tür mesaj içerir: "Opcode 1" ve "Opcode 2".

Opcode 1 ne anlama gelir? (Request/Reply?)

Opcode 2 ne anlama gelir?

Kanıt: Opcode 1: Request – Opcode 2: Reply.

ARP	44 Who has 10.82.111.101? Tell 10.82.64.1
ARP	44 10.82.111.101 is at 06:c3:ee:de:96:cd

Frame 77697: 44 bytes on wire (352 bits), 44 bytes captured (352 bits)	000
Linux cooked capture v1	001
Packet type: Broadcast (1)	002
Link-layer address type: Ethernet (1)	
Link-layer address length: 6	
Source: 06:f9:13:2c:3c:f5 (06:f9:13:2c:3c:f5)	
Unused: 0acf	
Protocol: ARP (0x0806)	
Address Resolution Protocol (request)	
Hardware type: Ethernet (1)	
Protocol type: IPv4 (0x0800)	
Hardware size: 6	
Protocol size: 4	
Opcode: request (1)	

ARP	44 10.82.111.101 is at 06:c3:ee:de:96:cd
-----	--

Frame 77698: 44 bytes on wire (352 bits), 44 bytes captured (352 bits)	0000
Linux cooked capture v1	0010
Packet type: Sent by us (4)	0020
Link-layer address type: Ethernet (1)	
Link-layer address length: 6	
Source: 06:c3:ee:de:96:cd (06:c3:ee:de:96:cd)	
Unused: 8daa	
Protocol: ARP (0x0806)	
Address Resolution Protocol (reply)	
Hardware type: Ethernet (1)	
Protocol type: IPv4 (0x0800)	
Hardware size: 6	
Protocol size: 4	
Opcode: reply (2)	
Sender MAC address: 06:c3:ee:de:96:cd (06:c3:ee:de:96:cd)	
Sender IP address: 10.82.111.101	
Target MAC address: 06:f9:13:2c:3c:f5 (06:f9:13:2c:3c:f5)	
Target IP address: 10.82.64.1	

5. TCP El Sıkışması (Task 9: TCP Traffic) Bağlantı kurmanın temeli.

Görev: Trafik içinde 3-Way Handshake (SYN -> SYN/ACK -> ACK) işlemini bulun.

Kanıt:

tcp.flags.syn == 1 (tcp.seq == 1 && tcp.len == 0 && tcp.ack == 1)						
Io.	Time	Source	Destination	Protocol	Length	Info
-	2052 7.596005566	10.82.111.101	199.232.25.91	TCP	74	59168 -> 443 [SYN] Seq=0 Win=62727 Len=0 MSS=8961 SACK_PERM TSval=2041477764 TSecr=0 WS=
-	2053 7.598262824	199.232.25.91	10.82.111.101	TCP	74	443 -> 59168 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460 SACK_PERM TSval=3921075507
-	2054 7.598259405	10.82.111.101	199.232.25.91	TCP	66	59168 -> 443 [ACK] Seq=1 Ack=1 Win=62848 Len=0 TSval=2041477766 TSecr=3921075507

6. DNS Sorguları (Task 10: DNS Traffic)

Soru: Bir bilgisayar google.com'a gitmek istediğinde önce DNS sunucusuna sorar.

Sorgu paketi (Query) hangi protokolle gider? (TCP/UDP?)

dns						
No.	Time	Source	Destination	Protocol	Length	Info
2043	7.589619846	10.82.111.101	169.254.169.253	DNS	84	Standard query 0x5e16 A normandy.cdn.mozilla.net
2044	7.590648329	10.82.111.101	169.254.169.253	DNS	84	Standard query 0x8038 AAAA normandy.cdn.mozilla.net
2046	7.593518805	10.82.111.101	169.254.169.253	DNS	76	Standard query 0x7364 A aus5.mozilla.org
2048	7.594447637	10.82.111.101	169.254.169.253	DNS	76	Standard query 0xaf54 AAAA aus5.mozilla.org
2049	7.594532628	169.254.169.253	10.82.111.101	DNS	128	Standard query response 0x7364 A aus5.mozilla.org CNAME mozilla.m
2050	7.594607849	169.254.169.253	10.82.111.101	DNS	140	Standard query response 0xaf54 AAAA aus5.mozilla.org CNAME mozilla
2062	7.601318924	169.254.169.253	10.82.111.101	DNS	170	Standard query response 0x5e16 A normandy.cdn.mozilla.net CNAME nc
2081	7.613437147	10.82.111.101	169.254.169.253	DNS	87	Standard query 0xec30 A services.addons.mozilla.org
2083	7.614231417	10.82.111.101	169.254.169.253	DNS	87	Standard query 0x6a1e AAAA services.addons.mozilla.org
2091	7.625395908	169.254.169.253	10.82.111.101	DNS	151	Standard query response 0xec30 A services.addons.mozilla.org A 151
2092	7.626059146	169.254.169.253	10.82.111.101	DNS	199	Standard query response 0x6a1e AAAA services.addons.mozilla.org A
2308	7.731711972	10.82.111.101	169.254.169.253	DNS	94	Standard query 0xfa5d A versioncheck-bg.addons.mozilla.org
2310	7.732424841	10.82.111.101	169.254.169.253	DNS	94	Standard query 0x996a AAAA versioncheck-bg.addons.mozilla.org
Internet Protocol Version 4, Src: 10.82.111.101, Dst: 169.254.169.253						
0100 = Version: 4						
... 0101 = Header Length: 20 bytes (5)						
Differentiated Services Field: 0x00 (DSCP: CS0, ECN: Not-ECT)						
Total Length: 62						
Identification: 0x24cc (9420)						
010. = Flags: 0x2, Don't fragment						
...0 0000 0000 0000 = Fragment Offset: 0						
Time to Live: 64						
Protocol: UDP (17)						
Header Checksum: 0x0000 (validation disabled)						

Kanıt:

7. HTTP vs HTTPS (Task 11 & 12) Bu bölüm, "Neden şifreleme şart?" sorusunun cevabıdır.

HTTP Analizi: Task 11'deki pcap dosyasında bir POST isteği (Login işlemi) yapılmıştır. Paket detaylarına bakarak gönderilen kullanıcı adı ve şifreyi açık metin (Cleartext) olarak bulun ve ekran görüntüsünü ekleyin.

Task11 .cap dosyasında herhangi bir şekilde parola ve kullanıcı adı çıkmadı. (Yanlış dosyayı kullanmış olabilirim, root/room/wireshark101 odasındaki her .cap ve .pcap dosyasına baktım) Ancak farklı bir odadan olan kullanıcı adı ve pw ektedir.

```
220 (vsFTPD 3.0.3)
USER vsftp
331 Please specify the password.
PASS supersecure
230 Login successful.
SYST
215 UNIX Type: L8
PORT 192,168,1,100,229,243
200 PORT command successful. Consider using PASV.
LIST
150 Here comes the directory listing.
226 Directory send OK.
QUIT
221 Goodbye.
```

Packet: 10. 6 client pkts, 0 server pkts, 12 turns. Click to select.

Entire conversation (300 bytes) Show as ASCII No delta times Stream 0

HTTPS Analizi: Task 12'de şifreli trafik vardır. Burada "Application Data" kısmına baktığınızda anlamlı bir metin görüyor musunuz? Gördüğünüzü (veya görmediğinizi) ekran görüntüsüyle kanıtlayın.

Task12 odasının .cap veya .pcap dosyası makinede görünmüyor.

8. Saldırı Analizi (Task 13: Analyzing Exploit)

Soru: Bu görevde saldırgan, sisteme sızmak için bir "Exploit" kullanıyor. Wireshark bu tür şüpheli durumları genellikle kırmızı ile işaretler veya uyarı verir.

Kanıt:

No.	Source	Destination	Protocol	Length	Info
1003	192.168.100.6	192.168.100.128	TCP	254	[TCP Retransmission] 445 - 47000 [PSH, ACK] Seq=4387 Ack=4568 Win=2100992 Len=200
1005	192.168.100.128	192.168.100.6	TCP	60	[TCP Dup ACK 1004#1] 47000 -> 445 [ACK] Seq=4568 Ack=4387 Win=64128 Len=0 SLE=4387 SRE



BÖLÜM C: Vaka Analizi (Evidence Files)

Senaryo: Şirket çalışanlarından Ann Dercover'ın, rakip firmaya "Gizli Tarif"i (Secret Recipe) sızdırdığından şüpheleniyoruz. Güvenlik ekibi, Ann'in bilgisayarından (192.168.1.158) çıkan şüpheli bir "Anlık Mesajlaşma" (IM - AIM Protocol) trafiği yakaladı.

Göreviniz: evidence01.pcap dosyasını analiz ederek aşağıdaki soruları yanıtlayın:

Suç Ortağı: Ann'in mesajlaştığı kişinin kullanıcı adı (Buddy Name) nedir?

```
.E4628778....Sec558user1.....  
- )....*..b.".....F.....Sec558user  
.....P.....n..n.....
```

İlk Temas: Yakalanan konuşmadaki ilk mesaj (comment) nedir?

```
...Here's the secret recipe... I just downloaded it from the file server. Just copy to a thumb drive and you  
er1..
```

Dosya Transferi: Ann karşı tarafa bir dosya göndermiş. Bu dosyanın adı nedir?

```
.....word/_rels/document.xml.rels ... (.....
.....^z ..y.7.d..1-.B..g%.<..V.....
```

```
root@ip-10-82-111-101:~/Desktop# tail -c +512 test.zip > temiz_recipe.docx
root@ip-10-82-111-101:~/Desktop# ^C
root@ip-10-82-111-101:~/Desktop# xxd temiz_recipe.docx | head -n 1
00000000: 0050 4b03 0414 0006 0008 0000 0021 007c  .PK.....!.
```

```
root@ip-10-82-111-101:~/Desktop# md5sum gercek_recipe.docx
8350582774e1d4dbe1d61d64c89e0ea1  gercek_recipe.docx
root@ip-10-82-111-101:~/Desktop#
```

[illegible]

Göreviniz: evidence02.pcap dosyasını analiz ederek kaçış rotasını çizin:

Kimlik Bilgileri: Ann'in kullandığı E-posta adresi nedir?

235 AUTHENTICATION SUCCESSFUL

MAIL FROM: <sneakyg33k@aol.com>

Güvenlik İhlali: Ann e-postasına giriş yaparken hangi Şifreyi (Password) kullandı?

NTU4cjAwbHo=

```
root@ip-10-82-111-101:~# echo "NTU4cjAwbHo=" | base64 -d
558r00lzroot@ip-10-82-111-101:~#
```

Gizli Sevgili: Ann'in e-posta attığı sevgilisinin (Mr. X) E-posta adresi nedir?

250 OK

RCPT TO: <mistersecretx@aol.com>

250 OK

Bavul Hazırlığı: Ann, sevgilisinden getirmesini istediği iki eşya (fake passport vb.) nedir?

Hi sweetheart! Bring your fake passport and a bathing suit. Address = attached. love, Ann

Eklenti Analizi: Ann e-postaya bir dosya eklemiş.

Bu eklentinin (Attachment) adı nedir?

Content-Disposition: attachment;
filename="secretrendezvous.docx"

Dosyayı dışarı aktarın ve MD5 Hash değerini yazın.

Konum Tespiti: Eklentinin içindeki bilgileri (veya gömülü görselleri) inceleyerek; Ann ve sevgilisinin buluşacağı Şehir ve Ülke neresidir?

BÖLÜM D: Mühendislik Vizyonu ve Etik (Reflection)

Tuşlara basmayı bıraktık, şimdi analiz zamanı. Bir mühendisi, bir "hacker"dan ayıran şey teknik bilgisi değil, etik duruşu ve veriyi yorumlama kabiliyetidir.

Aşağıdaki soruları kendi yorumunuzu katarak, teknik ve hukuki gerekçelerle cevaplayın.

1. Kırmızı Çizgi: Etik ve Hukuk (TCK Kapsamı) Senaryo: Bir kafede oturuyorsunuz, Wireshark'ı açtınız ve ortak ağdaki (Public Wi-Fi) trafiği dinlemeye başladınız. Amacınız kötü olmasa bile, sadece merak etseniz bile;

Hukuki Boyut: Bu eylem, Türk Ceza Kanunu (TCK) kapsamında hangi suçlara girer? Özellikle Madde 243 (Bilişim Sistemine Girme) ve Madde 132 (Haberleşmenin Gizliliğini İhlal) bağlamında değerlendirin.

Cevap: Teknoloji devrinde, etik en büyük çizgidir. Çoğu siber güvenlik uzmanının o etiği hiç geçmemeye çalışmasının bir sebebi var. Bir kere o çizgi geçilirse, her zaman geçilebilir. Yasa, hukuk; ne kadar bu konularda etkili olsa da, "etik" kaybedilmemesi gereken bir kavramdır. Beyaz, gri, siyah. Siyaha geçiş, gri ile başlar.

Profesyonel Duruş: Bir Siber Güvenlik Uzmanı, yetkisi (yazılı izni) olmayan bir ağda neden asla "Promiscuous Mode" açmaz? Bu durum kariyerinizi nasıl bitirebilir?

Cevap: Görülmemesi gereken veya beni ilgilendirmeyen paketlere burnumu sokmama gerek yok. Sistem tarafından üzerime atanan kısımla ilgilenmem gerekiyor.

2. Veri Yorumlama: "Görünenin Ötesi" Vaka 1'de dosya isminin sizi kandırmaya çalıştığını gördünüz.

Soru: İşletim sistemleri (Windows/Linux) dosya türünü anlamak için genellikle uzantıya (.txt, .jpg) bakar. Ancak bir Adli Bilişimci (siz), dosyanın gerçek kimliğini anlamak için Magic Bytes (Hex Signature) verisine bakar.

Analiz: "Dosya uzantısına güvenme, içeriğe (Header) güven" prensibini teknik olarak açıklayın. Bir saldırgan dosya uzantısını değiştirse bile, neden dosyanın başındaki o sihirli baytları (Örn: PK.. veya MZ) değiştiremez? Değiştirirse dosya çalışır mı?

Cevap: Dosya uzantısı yalnızca OS kısmına verilen bir sinyaldir. “Benim uzantım bu, beni bu şekilde aç.” Ama içerideki veriler farklı olabilir. .txt dosyasını, .jpeg yaparsak ve açmaya çalışırsak, OS resim açmaya çalışır. Alt katmanına inildiği zaman ise dosyanın verilerinin hala .txt olduğunu görürüz.

Magic Byte, DNA’dır.

3. Gürültü ve Sessizlik: "Ağda İz Bırakmak" Bu hafta yaptığınız analizlerde, saldırganın (veya Ann'in) ağda ne kadar çok iz bıraktığını fark ettiniz.

Soru: Bir saldırganın "Sessizce sızdım" demesi teknik olarak ne kadar mümkündür?

Basit bir Port Taraması (Nmap) bile ağda binlerce paket (gürültü) oluşturur.

Bu "gürültü", savunma tarafı (Blue Team / SOC) için neden bir avantajdır?

Yorum: "Mükemmel suç yoktur, sadece incelenmemiş log (veya pcap) vardır" sözünü bu haftaki deneyiminizle yorumlayın.

Cevap: Sessizce sızmak imkansızdır. Bağlantılar vardır, bağlantıyı sağlamak için gerçekleştirilen paketler vardır. Bu paketlerin varlığı bile sessizliği bozar. Karanlık bir sokakta, her kapıyı zorlarsanız; sokak lambaları yanar. Ancak, aynı sokakta her gün 1 kapıyı tıklatır ve su isterseniz “susamıştır” diyip su verip yollarlar. Sessizlik değil, zamana yayıp düşük profilde (low and steady) ilerlemek gereklidir.

Her işlemin bir fiziksel parmak izi, her toolun da kendine has bir yöntemi vardır.